

CASO AURORA MARKET:

Aurora Market es una empresa mexicana de comercio electrónico que durante los últimos años ha crecido rápidamente. Lo que comenzó como una pequeña tienda que vendía productos tecnológicos a través de redes sociales ahora se convirtió en una plataforma web donde miles de personas pueden registrarse, consultar productos, realizar compras y revisar el estado de sus pedidos. La plataforma cuenta con diferentes funcionalidades. Los clientes pueden crear una cuenta, iniciar sesión, buscar productos, agregar artículos al carrito, realizar compras y consultar información relacionada con sus pedidos. También existe un área destinada al personal de la empresa, desde donde algunos empleados administran productos, usuarios y pedidos. Como parte de su crecimiento, Aurora Market comenzó a almacenar cada vez más información de sus clientes: nombres, correos electrónicos, teléfonos, direcciones de envío e historial de compras. Hace algunas semanas ocurrió algo que llamo la atención del equipo de tecnología. Una persona del área de atención al cliente recibió el reporte de un usuario que aseguraba haber visto información que aparentemente pertenecía a otra cuenta. El equipo revisó rápidamente la situación, pero no pudo determinar qué había ocurrido. No sabían si se trataba de un error de la aplicación, un problema de permisos, una configuración incorrecta o una posible vulnerabilidad de seguridad. No tenían evidencia suficiente para confirmar que hubiera ocurrido un ataque. Sin embargo, el incidente hizo que la dirección de Aurora Market se hiciera una pregunta:

¿Qué tan segura es realmente nuestra aplicación?

Hasta ese momento, la empresa había corregido problemas conforme aparecían, pero nunca había realizado una evaluación formal de seguridad sobre su aplicación web. Por eso decidieron contratar a un equipo especializado en Ethical Hacking y Penetration Testing.

Mi borrador de análisis (notas):

Objetivo: Entender los riesgos reales y entregar información clara y útil para tomar mejores decisiones de seguridad.

Nivel de exposición: Aplicación accesible, información personal de clientes (compras, pedidos, historial)

Riesgos existentes: Exposición de información de un cliente a otro cliente, fallas de control de acceso, problemas de autenticación, gestión de accesos, permisos/privilegios, configuraciones incorrectas

Afectaciones: Exposición de datos personales, accesos no autorizados, pérdida de confidencialidad, integridad de pedidos o cuentas, consecuencias legales, daño reputacional.

Medidas preventivas:

Propuesta:

Condiciones:

Evaluación sólo a la aplicación Web

No evaluar: Redes sociales de la empresa, equipos personales de los empleados, cuentas de correo, proveedores, ni otros sistemas

Limitaciones: Acciones que interrumpan el funcionamiento de la plataforma o afectar información real de los clientes.

Horario de Pruebas: Horarios de menor actividad

Información:

- No entrega toda la información técnica de su infraestructura.
- Conocimiento: Aplicación web, base de datos, mecanismos de autenticación y diferentes tipos de usuario.
- No conocimiento: Infraestructura de la plataforma y tecnologías
- Se requiere saber qué información está expuesta a un atacante
- Documentación de las vulnerabilidades/exposiciones
-

OBJETIVO DEL PENTEST:

- Evaluar los mecanismos de autenticación y autorización de la aplicación web.
- Verificar que cada usuario pueda acceder sólo a la información que le corresponde.
- Identificar vulnerabilidades que puedan permitir acceso, modificación o exposición no autorizada de información

ALCANCE:

Sólo la aplicación web (dominios, usuarios, permisos)

FUERA DEL ALCANCE:

Redes sociales de la empresa, equipos personales de los empleados, cuentas de correo, proveedores, ni otros sistemas

No realizar pruebas destructivas

No evaluar empleados, proveedores

No realizar pruebas sobre sistemas fuera del dominio autorizado

PERMISOS

Cuentas de usuario de prueba para visualizar la interfaz del usuario

Dominio de la aplicación web

REQUERIDOS:

CONDICIONES ACORDADAS

Redes sociales de la empresa, equipos personales de los empleados, cuentas de correo, proveedores, ni otros sistemas

Limitaciones: Acciones que interrumpan el funcionamiento de la plataforma o afectar información real de los clientes.

TIPO DE PENTEST: GRAY BOX

Porque se cuenta con información parcial sobre la aplicación, cuentas prueba de usuario cliente, mecanismo de autenticación, roles de usuario, sin embargo, no se cuenta con información sobre la infraestructura, arquitectura interna, configuración de servidores o tecnologías y la información proporcionada por la empresa se utilizará únicamente para la evaluación

PLANIFICACIÓN

1. Objetivos

- Identificar los puntos de entrada de la aplicación web
- Analizar los mecanismos de autenticación y gestión de sesiones
- Verificar los roles y niveles de privilegios existentes
- Verificar los controles de autorización
- Evaluar si un usuario puede acceder, modificar o consultar recursos de otro usuario.
- Analizar la exposición de información
- Documentar las vulnerabilidades

2. Alcance:

- Vulnerabilidades
- Accesos de usuario cliente y sus permisos
- Filtración de datos externos
-

3. Permisos y condiciones:

- Cuentas de usuario de prueba para visualizar la interfaz del usuario
- Dominio de la aplicación web
- Redes sociales de la empresa, equipos personales de los empleados, cuentas de correo, proveedores, ni otros sistemas
- Limitaciones: Acciones que interrumpan el funcionamiento de la plataforma o afectar información real de los clientes.

4. Metodología que utilizar: PTES

5. Recopilación de información previa: Aplicación web, base de datos, mecanismos de autenticación y diferentes tipos de usuario.

6. Recursos necesarios: Dominio, cuenta de correo electrónico de prueba

FASES DEL PENTEST

1. RECONOCIMIENTO

Detectar la filtración de información de otros clientes desde la interfaz publica como desde la interfaz como cliente.

2. ANÁLISIS DE VULNERABILIDADES

Revisar los enlaces, interfaz de la plataforma, autenticación, autorización, control de acceso, gestión de sesiones, exposición de información, validación de entradas, APIs, componentes,

3. EXPLOTACIÓN

Explorar cada botón de la plataforma y revisar hacia donde se redirige

4. POST-EXPLOTACIÓN

Eliminación de rastros

Mantenimiento de accesos

Recopilación de información

5. INFORME: Técnico debido a que la empresa requiere las vulnerabilidades para que su equipo de desarrollo los corrija, en el viene el alcance, metodología, impacto y nivel de riesgo.

INVESTIGACIÓN.

METODOLOGÍA PTES

Porque permite estructurar la evaluación de seguridad desde la definición inicial del alcance y las reglas, la identificación, validación y documentación de vulnerabilidades. Además, la empresa Aurora Market requiere sólo evaluar la aplicación web en la que se maneja la información personal de sus clientes.

También permite establecer que sistemas serán evaluados, qué actividades estarán autorizadas y cuáles quedan fuera del alcance, además permite orientar las pruebas hacia los principales riesgos identificados.

Los resultados serán documentados mediante evidencia, descripción de riesgo, impacto y recomendaciones para que el equipo de desarrollo de Aurora Market lo pueda utilizar como base para corregir las vulnerabilidades identificadas,

Elaborado por: Marlen González Zamudio

Fecha: 5 de septiembre de 2026